

Gopher industries – Rood Remedy API

SIT375 – Capstone Team Project (A)

Author: Tesha Devi

Date: 11/05/2026

Ticket: RE034

1. Summary

This report fulfills the research task as described in the planner ticket, applied specifically to Gopher Food Remedy API. The app collects personal data (names, email addresses) and food/health-related tracking data. This report examines global privacy regulation (primarily GDPR), analyzes user consent mechanisms and data transparency practices, compares privacy policy structures, studies data collection/storage/sharing methods, and summarizes compliance requirements and best practices. Because the app may collect health-related data, GDPR Article 9 (sensitive data) requirements are included as a precaution. Where specific app details are unknown, this report provides general compliance principles that apply to any food or health tracking application.

2. Introduction and scope

2.1. Objective

To research and document privacy compliance requirement for specifically for Gopher Food Remedy API, ensuring alignment with legal and ethical standards for handling user data.

2.2. Scope

- Regulations: GDPR (EU), with mentions of CCPA (California), PIPEDA (Canada), and LGPD (Brazil).
- Functions: User consent, data collection, storage, sharing, and transparency.
- Deliverable: Summary of compliance requirements and best practices.

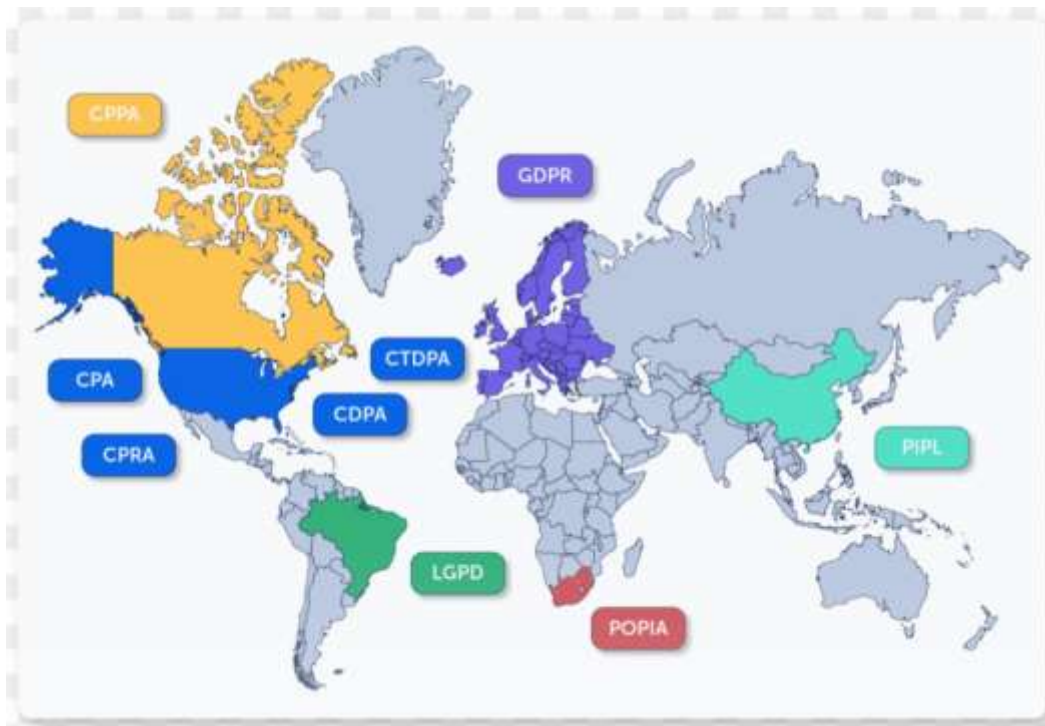
Why this matters: Non-compliance can result in fines up to €20 million or 4% of global turnover (GDPR). User trust is also a competitive advantage.

3. Global privacy regulations relevant to mobile apps

Regulation	Region	Key mobile app requirements
GDPR	EU	Explicit opt-in consent, right to access/delete data, data portability, breach notification (72h).
CCPA/CPRA	California (USA)	Opt-out of sale of personal info, “Do Not Sell My Info” link, data minimization.
PIPEDA	Canada	Meaningful consent, limited collection, safeguard obligation.
LGPD	Brazil	Similar to GDPR: consent, transparency, data subject rights.

Key common principles across all:

- Lawfulness Fairness Transparency
- Purpose limitation
- Data minimization
- Storage limitation
- Integrity and confidentiality





4. User Consent Mechanisms - Analysis

4.1. Types of Consent

Type	Definition	When required
Explicit (opt-in)	User actively agrees (e.g., checking a box, clicking “I agree”)	Sensitive data, marketing, tracking across apps
Granular consent	Separate choices for different purposes	When app has multiple data uses (analytics, ads, location, camera)
Implied consent	User action implies agreement (e.g., continuing to use app after notice)	Only for non-sensitive, optional features with clear notice

4.2. How Apps Implement Consent (Observed patterns)

Pattern 1: Splash screen consent dialog

- App launches with a pop-up asking for consent to collect data
- Typically includes “Accept All” and “Reject/Manage” buttons
- Example pattern seen in: News apps, e-commerce apps

Pattern 2: Granular Toggles

- User sees separate switches for different data users

- Example: Analytics: on/off | Marketing: on/off | Location: on/off
- Example pattern seen in: Productivity apps, fitness apps

Pattern 3: Just-in-time permission

- App asks for permission at the moment a feature is used
- Example: “App wants to access your camera to upload a photo”
- Example pattern seen in: Almost all mobile apps for camera, microphone, location

Pattern 4: iOS App Tracking Transparency (ATT)

- System-level pop-up required for cross-app tracking
- User sees: “Allow [App] to track your activity across other companies’ apps and websites?”

4.3. Best practices for consent

- Do Not use pre-ticked check boxes
- Do Not use scrolling as consent
- Make withdrawal as easy as giving consent (same number of taps)
- Record timestamp, version, and exact consent text for audit purposes
- Refresh consent every 12-24 months

The screenshot shows a mobile app interface for 'Food Remedy Co.' with the title 'Create Your Nutritional Profile'. The form includes the following elements:

- User Name** and **Age** input fields.
- Upload Picture** button with a camera icon.
- Select Allergies** section with buttons for Milk, Eggs, Wheat, Fish, Crustacean shellfish, Sesame, Soybeans, and Tree Nuts.
- Select Intolerances** section with buttons for Lactose, **Gluten** (selected), Caffeine, Fructose, Anime, Salicylate, and Sulfite.
- Dietary Form** section with buttons for Vegan, Vegetarian, No Sugar, Pescetarian, and **No Alcohol** (selected).
- Save** button at the bottom.

Gopher Food Remedy apps nutritional profile screen collects allergen and dietary health data. Under GDPR Article 9, explicit consent must be obtained before collecting this information.

5. Data transparency and privacy policy structures

5.1. What Gopher food remedy API must disclose

The privacy policy must explicitly state:

Required disclosure	Plain English wording example
What health data is collected	“We collect symptoms you enter such as bloating, nausea, or acid reflux”
Why health data is collected	“To recommend food remedies that may help your specific symptoms”
How long health data is kept	“Symptoms logs are delayed after 90 days. Account data deleted when you close your account”
Who health data is shared with	“We do not share your health symptoms with any 3 rd party. Dietary preferences are shared only with our recipe recommendation engines”
User rights	“You can download, correct, or delete your health data at any time from settings”

5.2. Recommended privacy policy structure for golfer Food Remedy API

Section	Content
1. At a glance (1 page)	Bullet points of what data, why, and user rights - suitable for mobile viewing
2. Full legal policy	Complete GDPR/CCPA complaint text on website
3. Health Data Appendix (special)	Separate section detailing GDPR Article 9 compliance for symptom data
4. Just-In-Time notices	Pop-ups when entering sensitive data (symptoms, location)

5.3. Comparison to other Wellness apps

App	Health data collected	Consent method	Policy readability
MyFitnessPal	Food logs, weight, exercise	Standard consent (criticized for being unclear)	Medium
Yuka	Product scans, no symptom data	Explicit consent for camera	Good

Recommended for gopher	Symptoms + dietary	Granular + explicit for health data	Layered + health appendix
------------------------	--------------------	-------------------------------------	---------------------------

6. Data collection storage and sharing

6.1. Collection

Method	Description	Examples
User-provided	User actively enters information	Name, email, profile photo, payment details
Automatically collected	App records data without user action	IP address, device ID, app usage, crash logs
Third-party SDKs	Embedded code from other companies collects data	Analytics (firebase), ads (google), crash reporting (sentry)
Permissions-based	App requests access to device features	Location, camera, contacts, microphone

6.2. Storage

Storage location	Security requirement
On device (local)	Encrypted at rest (minimum AES-256)
Cloud/backend servers	Encrypted in transit (TLS 1.3) + encrypted at rest
Third-party servers (SDK providers)	Data processing agreement (DPA) required

Retention principle: Data must be deleted or anonymized when the purpose is fulfilled.

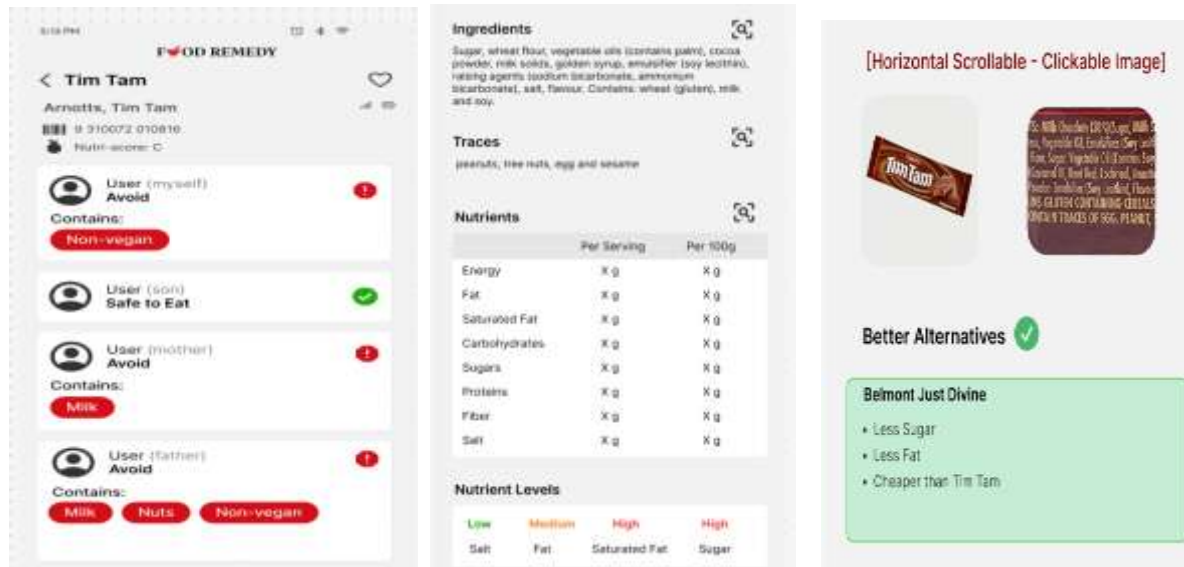
Example: temporary session logs = 30 days maximum.

6.3. Sharing

Mobile apps commonly share data with:

- Analytics providers (Google Analytics, Mixpanel, Amplitude)
- Crash reporting tools (Sentry, Crashlytics)
- Advertising networks (Google AdMob, Meta Audience Network)
- Cloud hosting providers (AWS, Google Cloud, Azure)
- Customer support Tools (Zendesk, Intercom)

Requirement: Each third party must sign a Data Processing Agreement (DPA) and only process data as instructed by the app developer.



7. Compliance requirements and best practices summary table

Requirement	Faction item for dev team	Deadline priority
Lawful basis	Document whether consent or contract applies	High
Consent management	Build granular consent screen with toggles	High
Privacy policy	Publish layered policy (short + full)	High
Right to access	Allow users to download their data	Medium
Right to deletion	Provide account deletion option	Medium
Data retention	Set auto-delete policies for food logs	Medium
Third-party audit	Review all SDKs for compliance	High
Health data consent (if applicable)	Separate explicit consent for any health data	High
Breach response plan	72-hour notification procedure	Low

8. Best practices specifically for Gopher Food Remedy API

Based on the app's nature as the food remedy/wellness application:

- Separate symptom data from other data - Store in a different database with stricter access controls
- Never pre-tick health consent - GDPR Article 9 requires active, unambiguous opt-in
- Add a "Health Data Dashboard" - Show users exactly what symptoms you have stored and let them delete individual entries
- Auto-delete old symptoms - 90 days is reasonable for food remedy correlation
- No symptoms data sharing - Make this a permanent policy, not just an option
- Use plain language for consent – Example: "we will use your symptoms 'bloating' to suggest ginger tea recipes. We never share this with anyone."
- Document everything - keep records of consent timestamps, versions, and user choice for regulatory audits

9. Conclusion

Gopher Food Remedy API, as a food-based wellness application that falls under GDPR Article 9 regulations for sensitive data. This requires explicit, granular consent mechanisms, a privacy policy with dedicated health data section, strict data minimization (auto-delete symptoms after 90 days), and a firm policy of never sharing symptom data with third parties. By implementing the requirements and best practices outlined in this report, Gopher Food Remedy API will meet legal and ethical standards for handling user data.

10. Reference

European Union (2016). REGULATION (EU) 2016/679 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL. [online] Europa.eu. Available at: <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng>.

GDPR (2018). *General Data Protection Regulation (GDPR)*. [online] GDPR. Available at: <https://gdpr-info.eu/>.

UK Government (2018). *UK General Data Protection Regulation*. [online] legislation.gov.uk. Available at: <https://www.legislation.gov.uk/eur/2016/679/contents>.

State of California Department of Justice (2024). *California Consumer Privacy Act (CCPA)*. [online] State of California - Department of Justice - Office of the Attorney General. Available at: <https://www.oag.ca.gov/privacy/ccpa>.

Bloomberg Law. (2023b). *California Consumer Privacy Laws – CCPA & CPRA*. [online] Available at: <https://pro.bloomberglaw.com/insights/privacy/california-consumer-privacy-laws/>.

www.edpb.europa.eu. (2020). *Guidelines 05/2020 on consent under Regulation 2016/679 | European Data Protection Board*. [online] Available at: https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-052020-consent-under-regulation-2016679_en.

Cejas, O.A., Sannier, N., Abualhaija, S., Ceci, M. and Bianculli, D. (2024). *GDPR-Relevant Privacy Concerns in Mobile Apps Research: A Systematic Literature Review*. [online] arXiv.org. Available at: <https://arxiv.org/abs/2411.19142>.

Traurig, G. (2023). *Increased Global Regulatory Focus on Mobile Apps: What Companies Should Know*. [online] Data Privacy Dish. Available at: <https://www.gtlaw-dataprivacydish.com/2023/04/increased-global-regulatory-focus-on-mobile-apps-what-companies-should-know/>.